

במפגש התשיעי של הקורס, המרצה מיכאל התמקד בניהול סיכונים בשרשרת האספקה (SCRM), נושא שנחשב לרוב ל"חוליה החלשה" בארגונים 1. לפי נתוני 2024, כ-66% מהתקיפות על ארגונים גדולים מתמקדות בשרשרת האספקה שלהם 2. להלן סיכום הנושאים המרכזיים שעלו בשיעור:

## 1. סיווג ספקי צד שלישי

- המרצה חילק את הספקים לשלושה סוגים עיקריים לפי רמת האבטחה והרגולציה שלהם:
- **ספק סטנדרטי (סוג 1):** ספקים קטנים שאינם עומדים בתקנים בינלאומיים, מה שהופך אותם למקור פוטנציאלי לפרצות 3, 4.
  - **ספק בעל דרישות מחמירות (סוג 2):** ספקים המחויבים לתקנים כמו SOC 2 ו-ISO 27001, ומבצעים מבחני חדירה (Penetration Testing) שנתיים 4.
  - **ספק פדרלי (סוג 3 - FedRAMP):** ספקים המעניקים שירותים לגופים ממשלתיים בארה"ב. שוק זה נחשב ל"אוקיינוס כחול"\*\*\* (Blue Ocean) – קשה מאוד להיכנס אליו בגלל הקשחות אבטחה קיצוניות, אך התחרות בו נמוכה מאוד 4, 5.

## 2. אסטרטגיות הגנה בשרשרת האספקה

- **S-BOM (Software Bill of Materials):** רשימת מרכיבים של המוצר (כמו במוצרי מזון) המאפשרת לארגון לדעת בדיוק מאילו ספריות וקוד מורכבת התוכנה שלו ואיזו אבטחה קיימת בכל רכיב 6, 7.
- **Exit Strategy (אסטרטגיית ניתוק):** חשיבות התהליך של סיום עבודה עם ספק. המרצה הדגיש זאת דרך מקרה שבו צה"ל מכר מדפסות ישנות מבלי להוציא מהן את הדיסקים הקשיחים, מה שגרם לדליפת מסמכים סודיים 8, 9.
- **הקשחת תהליך הפיתוח:** שימוש בסריקות אוטומטיות (כמו Wiz, Tenable ו-Nexus) כחלק מצינור הפיתוח (Pipeline) וביטול עדכוני תוכנה אוטומטיים במערכות קריטיות כדי למנוע החדרת קוד זדוני בזמן העדכון 6, 10.

## 3. איומים וטכנולוגיות חדשות

- **חולשת "Copy/Fail":** חולשה חדשה שהתגלתה במערכות לינוקס (מאז 2017) בעזרת כלי בינה מלאכותית (LLM) ואנשי חברת Wiz 11.
- **כלים פיזיים לתקיפה:** הוצג ה-Flipper Zero, מכשיר קטן ומסוכן שמסוגל לשכפל כרטיסי RFID, מפתחות רכב ואפילו לשלוט במערכות כריזה וסנסורים 12.
- **ההכרזה של מיקרוסופט:** מיקרוסופט טוענת שמרכיב ה"דפנדר"\*\*\* ב-Windows הגיע לרמה שבה אין צורך יותר בתוכנות אנטי-וירוס חיצוניות 2.

## 4. ניתוח אירוע בוחן (Case Study)

- בשיעור הוצג מקרה שבו האקר דרש 25,000 דולר בביטקוין לאחר שטען שפרץ לארגון 13.
- **הממצאים:** התחקיר העלה כי לא הייתה פריצה ישירה לארגון, אלא לספק של ספק (מדרגה שנייה בשרשרת האספקה) 14, 15.
  - **המסקנה:** המידע שדלף היה אמיתי אך ישן מאוד (לפי חותמות זמן), מה שמדגיש את הצורך בבדיקה שכל שרשרת האספקה (כולל קבלני משנה) עומדת בתקני הארגון 15, 16.
- דגשים לסוף הקורס:** המבחן יהיה אמריקאי, יותאם לחומר שנלמד בפועל, ובמפגש האחרון (מפגש 13) יועלו שאלות לדוגמה 1. המרצה ממליץ להתחיל לעבור על החומר באזור מפגש 11 1.